

Defend-The-Core

Infrastructure PME critique sécurisée

Document maître d'architecture
Synthèse des choix techniques et de la posture de sécurité

Conformité ANSSI · Zero Trust · DevSecOps · Infrastructure as Code

Table des matières

1. Contexte et problématique	3
1.1. Le risque de latéralité	3
2. Architecture réseau — zoning et VLANs	3
2.1. Principe directeur : default-deny	3
2.2. Règles de flux clés	4
3. Topologie et composants	4
3.1. Cartographie des VMs	4
4. Choix technologiques justifiés	4
4.1. OPNsense (pare-feu)	5
4.2. Wazuh (SIEM/XDR)	5
4.3. NixOS (bastion/PAW)	5
4.4. Ubuntu 22.04 (serveur métier)	5
4.5. Windows Server 2022 (AD/DNS/DHCP)	5
5. Les trois piliers de sécurité	5
6. Scénarios de validation	6
7. Infrastructure as Code (GitOps)	6
8. Conformité aux recommandations ANSSI	6
9. Structure de présentation en entretien	7

1. Contexte et problématique

Ce projet répond à un besoin concret rencontré dans la plupart des PME manipulant des données sensibles (cabinets d'audit financier, industrie, santé). L'infrastructure existante est typiquement « plate » : tous les postes et serveurs sont sur le même réseau, sans cloisonnement. Si un poste utilisateur est compromis par un phishing — vecteur d'attaque n°1 — l'attaquant peut se propager latéralement jusqu'aux serveurs de bases de données, compromettant l'intégralité du système d'information.

La reconstruction de cette infrastructure selon les recommandations de l'ANSSI vise trois objectifs : **empêcher la propagation latérale** (segmentation), **détecter et réagir** aux attaques (SIEM), et **sécuriser l'administration** (bastion immuable).

1.1. Le risque de latéralité

Dans un réseau plat, la compromission d'un seul poste suffit à un attaquant pour scanner l'ensemble du réseau, identifier les serveurs, et exploiter leurs vulnérabilités. C'est le schéma classique d'une attaque : phishing → compromission poste → reconnaissance réseau → mouvement latéral → exfiltration de données.

Le cloisonnement en zones de confiance (zoning) brise cette chaîne : même si un poste est compromis, l'attaquant ne voit et ne peut atteindre que ce qui lui est explicitement autorisé.

2. Architecture réseau — zoning et VLANs

L'infrastructure est segmentée en **quatre zones de confiance**, chacune correspondant à un VLAN distinct, cloisonnées par un pare-feu OPNsense en **default-deny**. Le niveau de confiance décroît du VLAN 99 (admin) au VLAN 10 (bureautique, non fiable).

Tableau 1 — Zones de confiance

VLAN	Zone	Réseau	Confiance	Rôle
10	Bureautique	10.10.10.0/24	Faible	Postes utilisateurs (vecteur d'attaque)
20	DMZ	10.10.20.0/24	Moyenne	Services exposés (proxy, VPN)
30	Critique	10.10.30.0/24	Haute	Serveurs métier, BDD
99	Admin/SIEM	10.10.99.0/24	Maximale	Surveillance, bastion

2.1. Principe directeur : default-deny

Le pare-feu OPNsense applique une politique **default-deny** : tout flux non explicitement autorisé est rejeté. Chaque interface possède une règle finale implicite *block any any*. La philosophie ANSSI du cloisonnement impose qu'un flux ne puisse traverser une zone que s'il est nécessaire, identifié et tracé.

Règle d'or : un flux ne peut aller que d'une confiance égale ou supérieure vers une égale ou inférieure, et uniquement sur des ports métier explicites. Le retour vers le VLAN 10 n'est jamais initié.

2.2. Règles de flux clés

Tableau 2 — Règles de flux inter-VLAN (extrait)

Source	Destination	Port(s)	Action	Justification
VLAN 10	VLAN 20	80, 443	Allow	Accès reverse proxy uniquement
VLAN 10	VLAN 30	*	Block	Isolation totale zone critique
VLAN 10	VLAN 99	*	Block	Isolation zone admin
VLAN 99 (bastion)	VLAN 30	22	Allow	SSH admin via bastion
Tous	VLAN 99 (Wazuh)	514, 1514	Allow	Flux de logs vers SIEM
WAN	VLAN 20	443	Allow	Accès VPN / services publics

La matrice complète des 20 règles est documentée dans le fichier `architecture/firewall-rules.md` du dépôt.

3. Topologie et composants

L'infrastructure est déployée sous VirtualBox. Chaque VLAN correspond à un réseau interne VirtualBox distinct, ce qui simule le zoning physique/VLAN 802.1Q sans équipement actif. OPNsense possède 5 interfaces réseau : 1 NAT (WAN) + 4 réseaux internes (VLANs 10, 20, 30, 99).

3.1. Cartographie des VMs

Tableau 3 — Composants de l'infrastructure

VM	Rôle	Technologie	VLAN	IP
OPNsense	Pare-feu / routeur	OPNsense	tous	.1/VLAN
Wazuh	SIEM / XDR	Wazuh + Elastic	99	10.10.99.10
Bastion	PAW / administration	NixOS	99	10.10.99.20
Win Server	AD, DNS, DHCP	Windows Server 2022	30	10.10.30.20
Ubuntu	Web + BDD	Ubuntu 22.04, Nginx, PG	30	10.10.30.10
Win 10	Poste employé	Windows 10	10	10.10.10.50
Kali	Attaquant (démon)	Kali Linux	10	10.10.10.100

4. Choix technologiques justifiés

4.1. OPNsense (pare-feu)

Choisi plutôt que pfSense pour son interface plus moderne, son orientation open-source et sa API REST native, essentielle pour l'automatisation (Infrastructure as Code). OPNsense assure le routage inter-VLAN avec filtrage strict, le NAT sortant, le port forwarding des services publics, et l'intégration avec Wazuh (alias dynamique pour l'active response).

4.2. Wazuh (SIEM/XDR)

Préféré à un Elastic pur pour ses capacités natives de détection (règles OSSEC), d'active response (blocage automatique d'IP) et de Security Configuration Assessment (vérification continue du durcissement CIS). Wazuh combine la collecte de logs, la corrélation, l'alerting et la réaction automatique en une seule solution.

4.3. NixOS (bastion/PAW)

C'est le choix le plus stratégique du projet. NixOS offre une caractéristique unique : la **configuration déclarative et immuable**. Toute la configuration système est décrite dans `configuration.nix`. Toute modification manuelle d'un fichier de configuration est **écrasée** au prochain `nixos-rebuild switch`. Il est donc impossible pour un attaquant de persister une backdoor dans un fichier de config système. De plus, l'état du système est versionnable dans Git → reproductibilité totale.

Argument clé : l'immuabilité empêche la persistance. Si un attaquant modifie `/etc/ssh/sshd_config` pour ajouter un mot de passe, NixOS l'écrasera au prochain déploiement.

4.4. Ubuntu 22.04 (serveur métier)

Distribution LTS standard pour le serveur Web + BDD. Le durcissement suit le CIS Benchmark (sysctl, auditd, UFW, PAM, SSH clés uniquement). PostgreSQL écoute uniquement sur localhost (pas d'exposition réseau), Nginx sert de serveur Web avec en-têtes de sécurité et TLS 1.2/1.3.

4.5. Windows Server 2022 (AD/DNS/DHCP)

Contrôleur de domaine Active Directory pour la gestion d'identité. Le durcissement inclut : SMBv1 désactivé (anti EternalBlue), Windows Defender activé (realtime + cloud), NLA pour RDP, audit complet, GPO de sécurité (politique de mots de passe, restriction logicielle).

5. Les trois piliers de sécurité

Tableau 4 — Les trois piliers

Pilier	Objectif	Mise en œuvre	Bénéfice
1. Zoning	Empêcher la propagation latérale	VLANs 10/20/30/99 + OPNsense default-deny	Poste compromis ≠ tout le réseau
2. Détection	Détecter et réagir aux attaques	Wazuh SIEM + active response (blocage IP auto)	Réaction temps réel, sans humain

3. Administration	Sécuriser l'accès privilégié	Bastion NixOS immuable + ProxyJump + FIDO2	Anti-persistence, traçabilité
-------------------	------------------------------	--	-------------------------------

6. Scénarios de validation

Pour un entretien, ce n'est pas l'installation qui compte, mais la démonstration que les défenses fonctionnent. Trois scénarios sont préparés :

Tableau 5 — Scénarios de démonstration

#	Scénario	Démo	Résultat attendu
1	Détection SIEM	Bruteforce SSH depuis Kali	Wazuh détecte → IP bloquée automatiquement (active response)
2	Zero Trust	Ping Win10 → VLAN 30/99	Échec : OPNsense bloque (default-deny), logs de drop visibles
3	PAW NixOS	SSH direct vs ProxyJump	Accès direct impossible ; Win → Bastion → Serveur fonctionne ; immuabilité

7. Infrastructure as Code (GitOps)

L'intégralité de l'infrastructure est versionnée dans un dépôt Git (GitHub). Chaque composant — configuration NixOS, scripts OPNsense, règles Wazuh, durcissement Ubuntu, GPO Windows — est décrit sous forme de code reproductible. Cette approche DevSecOps garantit :

- **Reproductibilité** : deux déploiements identiques produisent le même état.
- **Traçabilité** : chaque modification est un commit Git, auditable et réversible.
- **Collaboration** : revue de code (pull requests) avant tout changement de configuration.
- **Récupération** : en cas de compromission, redéploiement rapide depuis le dépôt.

Le dépôt contient également les 3 scénarios d'attaque reproductibles (Kali) et les dashboards Wazuh exportés, permettant de rejouer les démonstrations à volonté.

8. Conformité aux recommandations ANSSI

Tableau 6 — Correspondance ANSSI

Recommandation ANSSI	Mise en œuvre dans le projet
Cloisonnement en zones de confiance	4 VLANs (10/20/30/99) + pare-feu default-deny
Principe du moindre privilège réseau	Flux inter-VLAN explicites uniquement
Authentification forte	Clés SSH + FIDO2 (facteur matériel), root interdit

Surveillance centralisée	SIEM Wazuh : collecte, corrélation, alerting, réaction
Journalisation et traçabilité	auditd + logs forwardés vers Wazuh + sudo logging
Administration sécurisée	Bastion (PAW) + ProxyJump + immuabilité NixOS
Durcissement des systèmes	CIS Benchmark (Ubuntu, Windows) + sysctl + UFW
Gestion des mises à jour	Auto-upgrade sécurité (Ubuntu, NixOS, Windows)

9. Structure de présentation en entretien

La présentation suit une structure orientée **bénéfice métier** plutôt que technique :

Tableau 7 — Structure du pitch

Étape	Message	Argument
1. Problème	Le risque n°1 en PME est la latéralité	Un poste compromis = tout le réseau exposé
2. Architecture	Segmentation en zones (ANSSI/VLANs)	Moindre privilège réseau via OPNsense
3. Détection	Un réseau fermé ne suffit pas	Wazuh corrèle les logs et réagit en temps réel
4. Administration	Le point critique : l'accès privilégié	Bastion NixOS = immuabilité, anti-persistance
5. Bonus	Tout est Infrastructure as Code sur GitHub	Posture DevSecOps moderne

Les annexes suivantes détaillent chaque domaine :

- Annexe 1 — Réseau & OPNsense
- Annexe 2 — Sécurité & Wazuh (SIEM)
- Annexe 3 — Durcissement des serveurs (Linux & Windows)
- Annexe 4 — Administration sécurisée & Bastion NixOS